



16.4 Student Guide: Abusing Active Directory Certificate Services (AD CS)

Overview

In today's class, you will learn how to exploit vulnerabilities within Active Directory Certificate Services (AD CS) to elevate privileges within a Windows domain environment. The focus will be on understanding how misconfigurations in AD CS can be leveraged by attackers to obtain Domain Admin privileges, using insights from the "Certified Pre-Owned" article by SpecterOps.

Class Objectives

By the end of the class, you will be able to:

- Understand the role of Active Directory Certificate Services in a Windows domain.
- Identify common misconfigurations in AD CS that can be exploited.
- Perform attacks to abuse AD CS, including certificate request forgery and exploitation of misconfigured templates.
- Understand how these techniques can be used for privilege escalation and lateral movement in a domain environment.

Lab Environment

For this module, you will use the penetration testing Cloud Labs environment.

You will continue to use nested Hyper-V machines. Refer to the [Hyper-V guide](#) for additional information.

Slides

The slides for today's lesson are available [here](#).

01 Overview of Active Directory Certificate Services (AD CS) and Its Role in a Windows Domain

Active Directory Certificate Services (AD CS) is a crucial component within a Windows domain that provides public key infrastructure (PKI) services. It enables the creation,

management, and distribution of digital certificates, which are used to secure communications, authenticate users, devices, and services, and ensure the integrity of data.

Role of AD CS in a Windows Domain

1. **Issuing certificates:** AD CS issues digital certificates that can be used for various purposes, such as encrypting email, securing web traffic with SSL/TLS, and authenticating users and devices. These certificates bind the identity of an individual, device, or service to a public key.
2. **Authenticating users and machines:** Certificates issued by AD CS can be used to authenticate users and machines in a domain. For example, certificates are often used for smart card logins, enabling multi-factor authentication (MFA) within the domain.
3. **Securing Communications:** Certificates are used to establish secure channels for communication within the domain, such as securing web traffic via HTTPS, encrypting emails using S/MIME, and establishing secure VPN connections. This ensures that data in transit is encrypted and protected from unauthorized access.
4. **Supporting encryption and digital signatures:** Certificates provide the basis for encryption and digital signatures, which are essential to protect data confidentiality, integrity, and non-repudiation within the domain.

Common Setups and Configurations in Enterprise Environments

1. **Enterprise root and subordinate CAs:** In most enterprise environments, AD CS is configured with a hierarchy of Certificate Authorities (CAs). The root CA is at the top of the hierarchy, issuing certificates to subordinate CAs, which issue certificates to end entities (users, devices, services). This hierarchy allows for better security management and scalability.
2. **Certificate templates:** AD CS uses certificate templates to standardize the issuance of certificates. Templates define the properties and policies for the certificates issued, such as validity periods, key usage, and subject names. Different templates are used for different purposes, such as user authentication, code signing, and SSL/TLS.
3. **Autoenrollment:** AD CS can be configured to automatically enroll users and devices with the appropriate certificates based on group policies. This feature simplifies the management of certificates, ensuring that users and devices always have up-to-date certificates without manual intervention.
4. **Network Device Enrollment Service (NDES):** This service allows non-Windows devices, such as network routers and mobile devices, to request and obtain certificates from AD CS. NDES provides a way to integrate these devices into the PKI, ensuring that

they can securely communicate within the domain.

5. **Online responder:** In enterprise environments, AD CS may include an Online Certificate Status Protocol (OCSP) responder, which provides real-time certificate status checking. This ensures that clients can verify whether a certificate is still valid or has been revoked, improving the security of certificate-based authentication.

Importance of AD CS in Enterprise Security

AD CS is critical in enterprise security because it provides the foundation for trust within the domain. By issuing and managing certificates, AD CS ensures that only authorized users and devices can access sensitive resources. It also enables secure communication, protects data integrity, and supports compliance with security policies and regulations.

However, misconfigurations in AD CS can lead to significant security vulnerabilities, such as allowing attackers to forge certificates, impersonate users, and escalate privileges within the domain. Therefore, proper configuration and regular audits of AD CS are essential to maintaining the security and integrity of the Windows domain environment.

02 Activity: Identifying Misconfigurations

- [Activity File: Identifying Misconfigurations](#)

03 Activity Review: Identifying Misconfigurations

04 Certificate Request Forgery Activity

In this segment, you will learn how attackers can exploit vulnerabilities in Active Directory Certificate Services (AD CS) to forge certificate requests. The focus is on using tools like Certify and Rubeus to target misconfigured certificate templates, enabling the attacker to elevate privileges and impersonate privileged accounts within a Windows domain.

Background on Certificate Forgery

Certificate forgery in AD CS leverages misconfigurations in the certificate templates or the Certificate Authority (CA) settings. These misconfigurations can allow an attacker to request and obtain certificates that grant them unauthorized access to sensitive resources or enable them to impersonate other users, including domain administrators.

Misconfigurations that are typically exploited include:

- **Overly permissive enrollment permissions:** Some certificate templates may allow any authenticated user to request a certificate, which can then be used for malicious purposes.
- **Weak cryptographic settings:** Templates allowing short key lengths or easily guessed parameters can result in weak certificates that are more susceptible to attack.
- **User-controlled subject names:** Templates that allow users to specify the subject name or use wildcards enable attackers to create certificates for identities they don't legitimately control.

Tools Overview

Certify and **Rubeus** are two popular tools used by attackers to exploit AD CS:

- **Certify:** A tool from GhostPack that enumerates certificate templates, finds vulnerabilities, and crafts certificate requests based on identified vulnerabilities.
- **Rubeus:** A post-exploitation tool that manipulates Kerberos tickets. It can be used to request Kerberos tickets using a forged certificate, effectively impersonating a privileged account.

Demonstrating the Attack

1. Enumerate vulnerable templates.

- Start by using Certify to enumerate certificate templates in the domain with the following command:

Unset

```
Certify.exe find /vulnerable
```

- This will identify templates that allow any authenticated user to enroll for a certificate or have weak configurations.]

2. Craft a malicious certificate request.

- Once a vulnerable template is identified, the next step is to craft a certificate request. Use Certify to create a certificate for a privileged account, such as a domain administrator:

Unset

```
Certify.exe request /ca:<CAName> /template:<TemplateName>  
/altname:<Domain\Username>
```

- `<CAName>` is the name of the Certificate Authority, `<TemplateName>` is the vulnerable template, and `<Domain\Username>` is the account to be impersonated.
- This step allows the attacker to generate a certificate that will be recognized by the domain as valid for the impersonated user.

3. Use the forged certificate.

- With the certificate obtained, the attacker can now use it to authenticate as the impersonated user. This is typically done by requesting a Kerberos Ticket Granting Ticket (TGT) with Rubeus:

Unset

```
Rubeus.exe asktgt /user:<Username>
/certificate:<PathToCertificate> /password:<Password>
```

- The resulting TGT can be injected into the attacker's session, allowing them to operate with the privileges of the impersonated account.

4. Privilege escalation and lateral movement.

- With the TGT, the attacker can now move laterally within the domain or perform actions that require elevated privileges, such as accessing sensitive files, changing configurations, or adding new users to privileged groups.

Teaching Points

- **Critical analysis of misconfigurations:** Think critically about how small misconfigurations in AD CS can lead to significant security breaches. Proper configuration and regular audits can mitigate these risks.
- **The importance of defense in depth:** While AD CS misconfigurations are dangerous, they are part of a broader attack chain. There is thus a need for layered security measures, including monitoring, least privilege enforcement, and regular certificate audits.
- **Real-world implications:** These attacks have been used successfully in areas such as in advanced persistent threat (APT) campaigns.

By the end of this session, you should have a strong understanding of how attackers can abuse AD CS through certificate forgery, the tools used to execute these attacks, and the importance of securing AD CS in a Windows domain.

05 Activity: Exploiting Vulnerable Templates

- [Activity File: Exploiting Vulnerable Templates](#)

06 Activity Review: Exploiting Vulnerable Templates

07. Week 2 Review Activity (1:00)

For the remainder of class, we will review what we learned in a game called [Kahoot!](#)

- This game will provide examples of the types of multiple-choice questions that you may see on the Security+ exam.
- If you wish to continue working on your report instead, you may do so.
- Kahoot! will be conducted as an individual competition or in groups.